WAGESSE

Dossier de mise en production

Statut : préparation seulement. Aucun domaine de production n'a été basculé, aucune donnée n'a été migrée, aucun déploiement de production n'a été lancé.

Recommandation

NO-GO. La seconde recette n'a pas rejoué le cycle métier sur le serveur : le redémarrage, la rotation des mots de passe et la restauration d'essai attendent l'autorisation du propriétaire. Aucun domaine de production n'est basculé.

Checklist de sécurité

- Conserver `PAYMENT_MODE=MANUAL` ou n'activer un prestataire qu'avec des clés réelles, hors préproduction.
- Laisser PayDunya désactivé tant que le webhook et les clés ne sont pas revus.
- Ne pas copier les comptes 78001021, 78001022, 78002021 et 78002022.
- Ne pas réutiliser la base `wagesse_preprod`.
- Les en-têtes HSTS, nosniff, DENY et Referrer-Policy, ainsi que le retrait de X-Powered-By, sont dans le code. Ils ne sont pas encore visibles sur le site déployé.
- Traiter les alertes npm hautes avant l'ouverture publique. L'alerte critique Next.js vise Windows ; le VPS actuel est Linux.
- Déployer le correctif qui n'interrompt plus l'inscription sur l'écran SMS, ainsi que les pages légales.

Domaine

Le domaine de production prévu n'est pas `preprod.wagesse.fr`. `wagesse.fr` pointe aujourd'hui vers l'hébergement LWS, pas vers ce VPS. Le changer exige une validation séparée. Le certificat de préproduction ne couvre pas le domaine de production.

Sauvegarde et restauration

- Avant toute migration : `mysqldump` de la future base de production, fichier chiffré, hors du dépôt Git.
- Restauration à répéter sur une base jetable, puis contrôle du nombre d'utilisateurs et d'une demande.
- Cette restauration n'a pas été exécutée pendant la recette.

Migrations

`prisma migrate deploy` uniquement. Pas de `migrate reset`. Les six migrations déjà appliquées en préproduction sont le socle. Une base neuve de production doit les recevoir dans l'ordre, sans les données fictives.

Secrets

Fichiers root 600, hors dépôt. `JWT_SECRET`, mot de passe MariaDB et éventuelles clés de paiement sont distincts de ceux de la préproduction. Le compte applicatif ne lit pas le fichier d'environnement.

Déploiement

Même isolation que la préproduction : utilisateur système dédié, port local, vhost nommé, `nginx -t` avant rechargement. Le code n'est pas le commit de préproduction tant que la branche de recette n'est pas acceptée.

Après déploiement

- Certificat au nom du domaine de production.
- Connexion d'un administrateur créé pour la production, pas un compte de recette.
- Une commande manuelle de bout en bout, avec un vrai numéro vérifié.
- Les autres sites du serveur répondent encore.

Retour arrière

Conserver le dump précédant la migration et le précédent build. En cas d'échec : retirer le vhost de production, réactiver l'ancien processus, restaurer le dump sur une base neuve puis basculer l'application. Ne pas restaurer par-dessus une base qui aurait déjà reçu des paiements réels sans décision explicite.